

Detecting

 Detecting threats pertain to situations where the involvement, participation, or membership of an individual can be deduced through observation.

D.1

Observed communications

Detecting through observed communications

D.2

Application side effect

Detecting through (trans)action side effects

D.3

System responses

The existence of an item of interest is revealed in a system response (which can be evoked deliberately or given accidentally).

Examples

Infer user of a website: Observing communication with a service to infer that a person is a user (e.g., adult website).

Telemedicine e-health system: Communication with a telemedicine service implies the user is a patient.

Tor network participant: Participation in the Tor network can be determined by observing traffic.

Wireless transmissions: Wireless transmissions are detectable by other devices nearby.

Examples

System logs: Log files on a shared system reveal applications used or actions taken by other users.

Deleted application: Deleted applications may leave behind traces (configuration, temporary files).

Hidden data: When steganography is used to hide data, the increased file size may still indicate the existence of that hidden data.

Detecting content tracing test result communication: A user reporting a positive test result in a contact tracing app may trigger observable communication that discloses medical information.

Examples

Wrong password: A ‘wrong password’ error message reveals the existence of the account.

Firewall: A firewall responding with ‘port closed’ reveals the existence of a device at the IP address.

DB access denied: An error message stating ‘insufficient access rights’ may inadvertently leak the existence of a specific record.

Bounced email: The existence of email accounts can be inferred from bounced emails.

Address already registered: An error message stating ‘address already registered’ when subscribing to a political newsletter reveals a current member.

Cached browser resources: To speed up the loading of websites, browsers can provide certain remote resources from their local cache. This enables detecting which resources were already cached.

Criteria

Can the communication be observed?

Can information be inferred from the observed communications?

Criteria

Do actions in the system have side effects (e.g., saving a file, writing to a log, triggering other transmissions)?

Are these side effects observable?

Criteria

Does the system show status messages (informational, warnings, errors) when retrieving data?

Are the status messages distinct when an item (a file, user, ...) does not exist compared to not having access rights?

Impact

Sensitive context: In sensitive contexts (medical, whistleblower) detecting service usage may have a severe impact on the user.

Impact

Infer sensitive data: Sensitive information may be deduced from observed side effects, such as communication.

Impact

Detecting can lead to security threats: Being able to detect the existence of certain items can be a stepping stone to security threats.

Existence: Simply knowing the existence of data may be sufficient to infer sensitive information.

Additional Info

Tor: Services like Tor conceal the destination but the utilization of Tor can still be detected.

Additional Info

Dummy traffic: Dummy traffic can be used to conceal actual events.

Additional Info

Redesign system response: Prevent information leakage by not revealing the existence of items in system responses.